

GraphQL Blog — Security Audit

Project: GraphQL Blog

Technology: Python, FastAPI, Strawberry GraphQL, SQLAlchemy, PostgreSQL

Location: /home/dominic/Documents/graphql-blog

Report #: 9/20

Issue	Severity	Description
No refresh tokens	Medium	JWT tokens are long-lived
No email verification	Medium	Anyone can register
CORS likely permissive	Low	May need tightening
No SQL injection	Good	Prevented by SQLAlchemy

Security Audit

Findings Summary

Severity	Count	Description
Critical	0	No critical issues found
High	0	Issues requiring attention
Medium	2	Best practice improvements
Low	3	Informational

High Severity Issues

None found.

Medium Severity Issues

- No rate limiting on most endpoints
- Security headers not configured

Security Checklist

Control	Status	Notes
HTTPS enforced		Via Render/GitHub Pages
JWT signing		HS256 with secret key
Password hashing		bcrypt via passlib

Control	Status	Notes
CORS configured		Allow all origins (dev)
Rate limiting	Only on AI Chat Proxy	Per IP tracking
SQL injection prevention		SQLAlchemy ORM
XSS protection	User content rendered as HTML	HTML sanitization if needed
CSRF protection	Not implemented	Token-based for state-changing
Input validation		Pydantic schemas
Security headers		Recommended but not configured

Recommendations

1. Implement rate limiting on all endpoints
2. Add security headers middleware
3. Use environment-specific CORS origins
4. Implement API key rotation
5. Add request logging for audit trail